Exam: Secure Computer Systems 1
1DT072
2024–06–10

Teacher: Paul Fiterau-Brostean (tel. 0040720114646)
Time: 8.00–13.00

Instructions: The exam has 11 sections. To pass the exam you need to get approximately 2/3 of the possible total score.

Hand in **only the answer sheet**, with your answers clearly marked. If you make mistakes, ask for another answer sheet. If you mark more than one answer to a question, you will get no score. **Please also read** the instructions on the answer sheet!

Good luck!!

---

1 Foundations

Question 1 If there is a vulnerability with respect to *confidentiality* (the security property) the following is **TRUE**:

A. Botnets are often used for attacking this vulnerability

B. A reasonable protection involves encryption/decryption

C. A trojan could reduce the accountability

D. Computing file hashes may be part of a mitigation

E. The threat can be controlled by proper access control

Question 2 Consider a ransomware attack – which of the basic security properties is most affected?

A. authenticity

B. confidentiality

C. integrity

D. accountability

E. availability

Question 3 Which of the following is **TRUE** about the classic design principles of Saltzer and Schroeder?

A. *Fail-safe default* says default access should be configured in a safe way

B. *Open design* says widely accepted design patterns should be employed when implementing security mechanisms.

C. *Economy of mechanism* says you should consider the cost of implementing security

D. *Separation of privilege* says protection mechanisms should be separated from each other, to avoid unintended overlap

E. *Least privilege* says all users should have only the minimum of privileges needed

---

2 Web and data security

Question 4 Forbidding the use of the ".." character can best defend against which attack?

A. command injection

B. path traversal

C. SQL injection

D. SYN flood attack

E. XSS

Question 5 In a shell injection attack, which is **TRUE**?

A. The attack can be avoided by the use of *parameterized queries*

B. Race conditions are fundamentally important to protect against shell injections

C. If shell comment characters and boolean expressions are filtered, shell attacks are impossible

D. The attack injects data which is interpreted as shell code

E. The attacker can inject machine code in the shell query through a stack overflow

---

Question 6 The following is **FALSE** regarding XSS (cross-site scripting) and CSRF (cross-site request forgery) attacks:

A. Properly sanitizing inputs prevents all CSRF attacks

B. Disabling execution of client-side scripts prevents all XSS attacks

C. If XSS attacks are made impossible, CSRF attacks are still possible

D. An XSS attack can be used to perform a CSRF attack

E. CSRF attacks typically involve the victim performing a state-changing action

---

Question 7 Which of the following attacks can best leverage *homographic encodings*?

A. command injection

B. SQL injection

C. XSS

D. phishing

E. CSRF

---

3 Asymmetric Cryptography and Signatures

Question 8 A group of 10 users want to establish secure channels among themselves. This means, every two users should be able to communicate in a way that is indecipherable by the other users. For this purpose, they are deciding between using either symmetric or asymmetric cryptography. Which of the following statements is **FALSE**?

A. Leakage of a secret key would compromise more secure channels if asymmetric cryptography is used

B. A user would have to know more secret keys if symmetric cryptography was used

C. Adding a new user to the group is easier for asymmetric cryptography (i.e., it entails generating fewer keys)

D. Symmetric encryption algorithms are generally faster

E. Symmetric cryptography requires fewer keys in total

Question 9 You are given the certificate hierarchy in Figure 1.

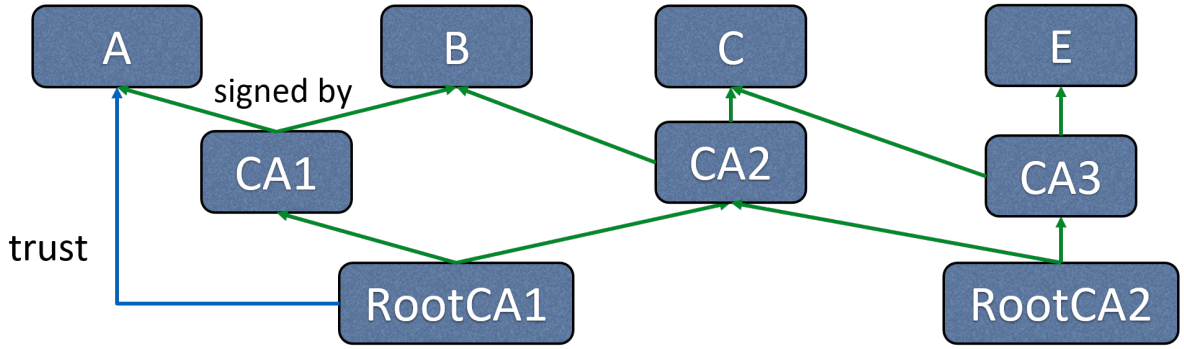

Figure 1 Certificate Hierarchy

Entity A's trust store contains **only** RootCA1's self-signed certificate ($Cert_{RootCA1(RootCA1)}$). Select the certificate chain that A will be able to successfully validate. Note that $Cert_{X(Y)}$ can be interpreted as a certificate containing Y's public key that has been signed by X.

A. $Cert_{CA2(B)}$, $Cert_{RootCA1(CA2)}$

B. $Cert_{CA1(B)}$

C. $Cert_{CA3(C)}$, $Cert_{RootCA2(CA3)}$

D. $Cert_{CA3(E)}$

E. $Cert_{CA2(C)}$, $Cert_{CA3(C)}$

Question 10 In the first lab, you used S/MIME certificates for secure email. Which of the following is **TRUE**?

A. Verifying a digitally signed email requires the certificate of the sender

B. Sending a digitally signed email requires the certificate of the recipient

C. Sending a digitally encrypted email requires the certificate of the sender

D. Encrypting a digitally signed email requires the certificate of the sender

E. Decrypting a digitally encrypted email requires the certificate of the sender

---

4 Sandboxing and Virtualization

Question 11 AppArmor is used to restrict the capabilities of a program, and in doing so protect the operating system. Which of the following is the design principle (by Saltzer et al) does AppArmor **most specifically** address?

A. *Least common mechanism*

B. *Open design*

C. *Least escalation*

D. *Psychological acceptability*

E. *Complete mediation*

Question 12 The terms sandboxing and virtualization can be easy to confuse. What is **TRUE** of the following?

A. Virtualization is mainly a software feature, and not helped much by hardware support

B. Sandboxing abstracts underlying components

C. Sandboxing protects 'sandboxed' applications from viruses affecting the system

D. Virtualization can protect the system against viruses

E. Sandboxing may limit an application's access to system resources

---

5 Identification and authentication

Question 13 The attack on LinkedIn in 2012 resulted in the leak of 177.5 million password hashes, which appeared in a data dump in 2016. The passwords were stored with plain hashing using the SHA1 algorithm. About 98% of them were cracked within 6 days from the release of the dump.

In an attack on MySpace in 2013, 362 million accounts and their password hashes were leaked, which appeared in a data dump also in 2016. These passwords were also hashed with SHA1, but after being converted to lowercase and truncated to max 10 characters.

Which statement is **TRUE**?

A. Since only the password hashes were leaked, the passwords themselves were safe

B. Using the MD5 hash algorithm would have been even worse

C. Using the SHA1 algorithm was a bad idea since it is fast

D. Using the same password on both sites would not have been a problem if the sites had used different hash algorithms

E. Converting and truncating passwords makes it unfeasible to find the original password

---

Question 14 *salted hashing* protects against a dictionary attack primarily because:

A. Both the password and the salt are unknown to the attacker

B. The attacker cannot pre-compute the dictionary used to crack the passwords

C. It requires a more secure hashing algorithm

D. It is slower to compute than regular hashing, causing attacks to take more time

E. The entropy of the password is increased, making it more difficult to crack

---

6 Information flow

Question 15 Information entropy is a measure of the uncertainty of the values of a variable, based on their probabilities. The value can be interpreted as the average size (in bits) of an optimally encoded value. Below, $H(X)$ is the entropy of the variable X, and n is the number of possible values for X. What of the following is **TRUE**?

A. If X can only have one value, then $H(X) = log_2(n)$

B. The maximum entropy is $H(X) = log_2(n)$

C. $0 \leq H(X) \leq log_2(n)$, with minimal value for a random distribution of X, and maximal value when X can only have a single value

D. $0 \leq H(X) \leq 1$, with maximal value for a random distribution of X, and minimal value when X can only have a single value

E. $H(X)$ can be negative in special cases

Question 16 y and z are variables, such that $y, z \in \{0, ..., 15\}$ with equal probabilities. The variables are secret, and used in programs whose execution produces the non-secret output x. Select the program whose execution leaks the least amount of information regarding y.

A. $\boxed{x := (y + z) \bmod 4}$

B. $\boxed{x := y^z}$

C. $\boxed{x := y \text{ xor } z}$

D. $\boxed{x := y * z}$

E. $\boxed{x := y/z}$

---

7 Access control

Question 17 The access control matrix can be implemented using Capability Lists (CL) or Access Control Lists (ACL). Which is better, when?

A. CLs are better when the owner of an object often needs to revoke access rights to it

B. CLs are better when objects have owners, who can quickly see who has access to their objects

C. ACLs give a better overview of which subjects have access to a particular object

D. ACLs often allow delegation of rights between subjects

E. ACLs are better when subjects often need to have all their rights revoked

---

Question 18 Mandatory Access Control (MAC) differs from Discretionary Access Control (DAC). What of the following is **FALSE**?

A. On a standard Linux system, the root user can read and write any file

B. Role-Based Access Control is typically MAC

C. "Classic" Linux file protection supports DAC

D. In a DAC system, central policies define the access rights

E. When using DAC, all objects typically have an owner

---

8 Software security

Question 19 In Lab 3, you used Metasploit to attack the different systems. For a successful attack, you needed a *vulnerability*, an *exploit* and a *payload*. What is the relationship between an exploit and a vulnerability?

A. An exploit is a type of vulnerability

B. A vulnerability is a type of exploit

C. An exploit is used to expose a vulnerability

D. A vulnerability is the result of an exploit

E. Exploits and vulnerabilities are unrelated

Question 20 The C program (below) executes a `sensitive` function only if the user provides a correct 3-digit number. The constant `PIN` stores the correct PIN, but its contents are unknown, other than the fact that it is a 4-byte string in which a 3-digit number is stored. The binary is compiled for a 32-bit architecture.

```
#define PIN "..." // 4-byte string storing 3-digit number
void sensitive () {
  // . . .
}
int main() {
  char secret[] = PIN;
  char input[4]; // make room for end of string char '\0'
  printf("Input 3-digit PIN: \n");
  gets(input);
  if (strncmp(input, secret, 3) == 0) {
    printf("Authenticated successfully\n");
    sensitive();
    return 1;
  } else {
    printf("PIN is incorrect\n");
    return 0;
  }
}
```

What is the measure that best would address the buffer overflow vulnerability in the given program.

A. making the stack non-executable

B. increasing the size of the array `input`

C. replacing `gets` with a safer alternative (e.g. `fgets`)

D. enabling address randomization

E. compiling for a 64-bit architecture

---

9 Privacy and Tracking

Question 21 A web server can find out a lot of information about the clients visiting its web pages, e.g. by sending Javascript code which gets executed in the web browser. (Note that this is not an XSS attack, since the information is sent back to the same web server that sent the Javascript code.)

Suppose you run a web server and want to keep track of your clients. Which of the following would be the *least* useful information that an HTTP request could contain?

A. the size of the browser window

B. the list of installed system fonts

C. the language preferences in the browser

D. the universal time (UTC) when doing the request

E. user agent string (which describes the web browser to the server)

Question 22 Tor browser protects you from being tracked when surfing the web primarily by:

A. making your browser appear indistinguishable from many others

B. disabling script execution

C. using highly customized parameters in HTTP requests

D. sending a Do-not-track header to tell web services not to track

E. launching threads for separate websites in separate containers

---

10 Network security

Question 23 Protecting against DDoS (distributed denial of service) attacks *based on address spoofing* can be very hard. What is **most often** an efficient protection?

A. Upgrading from IP version 4 to version 6

B. Supporting HTTPS instead of HTTP

C. Upgrading your network interface to handle more incoming traffic

D. Having endpoint routers filter packets with spoofed addresses when they exit the local network, as they enter the Internet

E. Having endpoint routers filter packets with spoofed addresses when they enter the local network, as they arrive from the Internet

---

Question 24 A security mechanism provides different forms of protection. What is **FALSE** of the following?

A. IPsec in tunnel model provides confidentiality of application ports

B. TLS provides confidentiality of data exchanged between applications

C. SYN Cookies protect availability in the transport layer

D. S/MIME protects authenticity and confidentiality of email.

E. Using SMTP over TLS ensures end-to-end email confidentiality.

---

11 Ethics in Security

Question 25 (2 points)

The Online Safety Bill is a recently enacted set of laws in the UK designed to regulate the Internet and make it safer for users. One of its key provisions is to force messaging services to examine contents of encrypted messages for illegal content including: child abuse content, promoting self-harm, terrorism, etc. Platforms like WhatsApp and Signal have said they cannot access or view anybody's messages without destroying existing privacy protections for all users, and have threatened to leave the UK rather than compromise message security.

Suppose you are based in the UK and you rely heavily on WhatsApp to communicate with friends and family. Decide whether you will continue using this service. Analyse the issue by applying *more than one* ethical aspect (e.g. consequences, duties, virtues, freedom, fairness, or relations). Do not simply state "this is what I would do". Answer in the box at the bottom of the answer sheet. (You may want to think and formulate an answer before you write it there.)

Note: For 1 point, you need to show reflection and use basic ethical argumentation. For 2 points, you need to argue showing (relevant) understanding of ethical principles. Just stating "this is what I would do" is not enough for any score at all.

Good luck!

Score	**Exam: Secure Computer Systems 1 (1DT072)** **Date: 2024–06–10**
	Exam code:

Instructions: Mark clearly in the table below ***no more than one*** answer per question, by checking or covering the letter for your choice. ***Hand in only this page.*** If you find one of the questions strange or want to clarify your answer, mark ***the question box*** with a $\star$ and explain ***on the back of this sheet***, e.g, what you think is the problem and what assumptions you had to make to answer the question.

Question	Answer				
1	A	B	C	D	E
2	A	B	C	D	E
3	A	B	C	D	E
4	A	B	C	D	E
5	A	B	C	D	E
6	A	B	C	D	E
7	A	B	C	D	E
8	A	B	C	D	E
9	A	B	C	D	E
10	A	B	C	D	E
11	A	B	C	D	E
12	A	B	C	D	E

Question	Answer				
13	A	B	C	D	E
14	A	B	C	D	E
15	A	B	C	D	E
16	A	B	C	D	E
17	A	B	C	D	E
18	A	B	C	D	E
19	A	B	C	D	E
20	A	B	C	D	E
21	A	B	C	D	E
22	A	B	C	D	E
23	A	B	C	D	E
24	A	B	C	D	E

Answer to question 25 (please write LEGIBLY and only write inside the box):